

課題④ ポートスキャンのパケット解析

目的

探査段階の中心となるポートスキャンの実習を行う。Nmap で探査中のパケットを調査する。パケットを分析することにより、探査の仕組みを確認する。

事前準備

1. server と router の VM を起動する。
2. TCP の 3way handshake を調査する。
3. ホスト検出，ポートスキャン手法について調査する。
4. telnet と SSH の違いについて調査する。

注意事項

- ・ 不用意にインターネット上のサーバに対して Nmap を利用してポートスキャンを行うと，スキャンを受けている側からすればアタックを受けているように見える。演習で構築した VM 以外のサーバ等に対してスキャンしないようにすること。
- ・ 自分で構築，設定していない IP アドレスのマシンへの通信が勝手に発生している場合は，解析に含めなくてよい。

手順

(1) Nmap を使ったホスト検出

サブゴール：探査用マシン (server) が属するネットワーク内で動作しているすべてのマシンをリストアップする。

- 1 server で Wireshark を起動する。
- 2 次のコマンドを実行して IP アドレスの指定範囲をスキャンすることで動作してい

るマシンを探し、IP アドレスを確認する。(Wireshark でパケットを記録すること)

nmap -sn スキャン対象の IP アドレスの範囲

(例えば `nmap -sn 172.20.1.1-254` あるいは `nmap -sn 172.20.1.0/24` アドレスの範囲はあくまで例です。どの範囲を指定すべきかは各自で考えること。) 解析に時間がかかる場合には、範囲を限定すること。

※ ネットワーク内のすべてのマシンが検出されていることを確認すること。

[解説]: 個々のパケットではなく TCP ストリームを解析したい場合には、解析したい TCP ストリーム中のパケットを選択し、右クリックして表示される Follow TCP Stream を選択する。表示されるウィンドウ中の文字色の違いを把握しておくこと。

まず nmap についての説明を行う。nmap は、ネットワーク調査およびセキュリティ監査を行うためのオープンソースのツールである。生の (raw)IP パケットを用いて、ネットワーク上でどのようなホストが利用可能になっているか、これらのホストが提供しているサービス (アプリケーション名とバージョン) は何か、ホストが実行している OS(OS 名とバージョン) は何か、どのような種類のパケットフィルタ/ファイアウォールが使用されているかなど、その他数多くの特徴を斬新な方法で判別する [1]。ここでは -sn オプションを用いる。このオプションを使うと、Nmap は ping スキャン (ホスト発見) のみを実行し、応答した利用可能なホストの一覧を出力する。それ以上の調査 (ポートスキャンや OS 検出など) は行わない。ping スウィープや ping スキャンとも呼ばれるこの手法は、デフォルトで、ICMP エコー要求と 80 番ポート宛ての TCP パケットを送信する。高い権限を持つユーザが、ローカリーサネットネットワーク上のターゲットのスキャンを試みる場合は、-send-ip が指定されていない限り、ARP 要求 (-PR) が用いられる [4]。ping スキャンの

実行結果を図 1 に示す。探索範囲には 192.168.100.1 ~ 192.168.100.5 を指定した。プライベートアドレス空間 192.168.100.0/24 に属するホストは router と server のみであり、それぞれ IP アドレスに 192.168.100.1 と 192.168.100.2 を割り当てている。したがって、これらのアドレスを含まないアドレス空間に対する ping スキャンは応答が期待できないため、上述のような探索範囲を指定した。

図 1 の結果から、ping スキャンの結果として、192.168.100.1 と 192.168.100.2 の 2 つの IP アドレスが検出されたことがわかる。これはそれぞれ router と server の

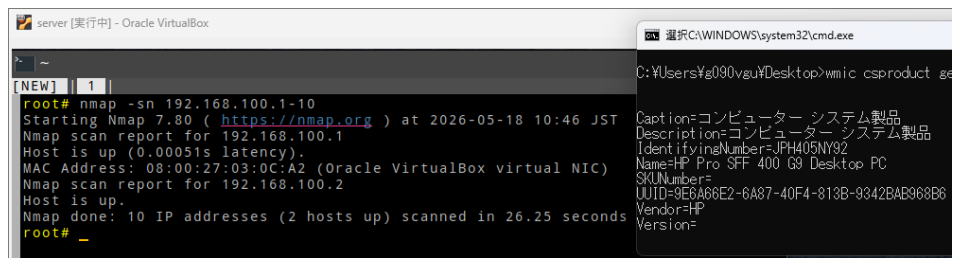


図1 ping スキャンの結果

IP アドレスであり、想定通りの結果が得られた。

- 3 パケット解析した結果（パケットをキャプチャした結果など）を用いて、OSI 参照モデルのどの層で、どのような手順で、どのように、どのような情報が、やり取りされてホスト検出の仕組みが、実現されているかをレポートで報告しなさい。

ping スキャンを実行した際に wireshark でキャプチャされたパケットの一覧と各パケットの詳細について図 3, 4, 5, 6 に示す。

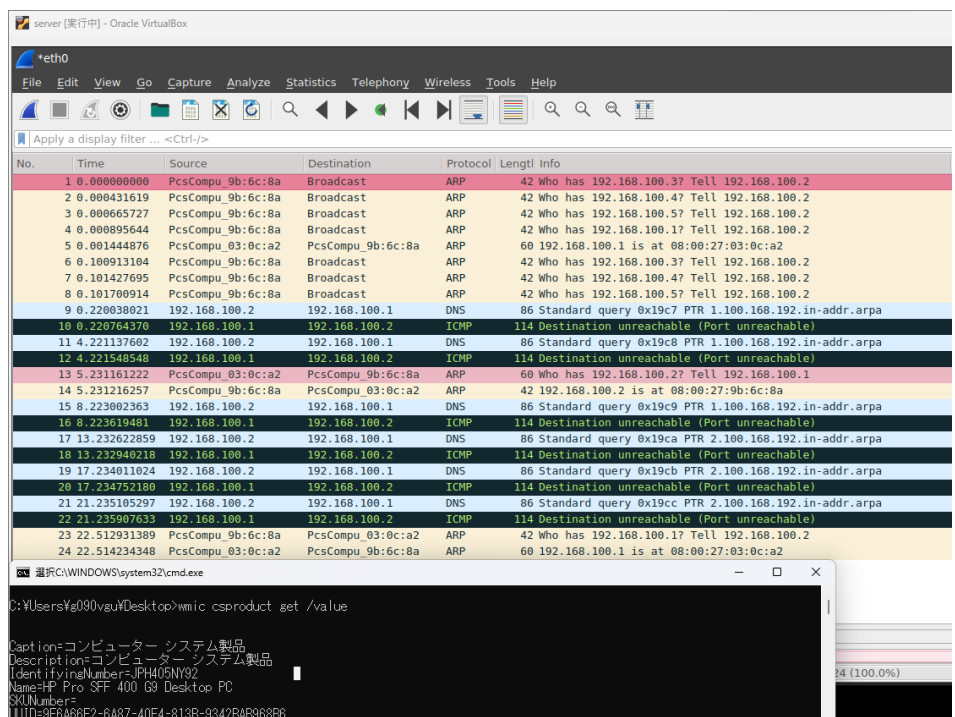


図2 ping スキャン時にキャプチャされたパケット一覧

図 2 は ping スキャンを実行した際に wireshark でキャプチャされたパケットの一覧であり、キャプチャ順にソートされている。ここから、ping スキャンの実行に伴い、ARP リクエスト・DNS・ICMP といったプロトコルのパケットがキャプチャされたことがわかる。最初にキャプチャされているパケットが ARP によるものであり、まず No.14 にかけて特定の MAC アドレスからブロードキャストで合計 4 つのパケットが送信されていることが分かる。info フィールドには Who has 192.168.100.[1,3,4,5] と記載されている。例として図 2 における No.1 のパケットの詳細を図 3 に示す。

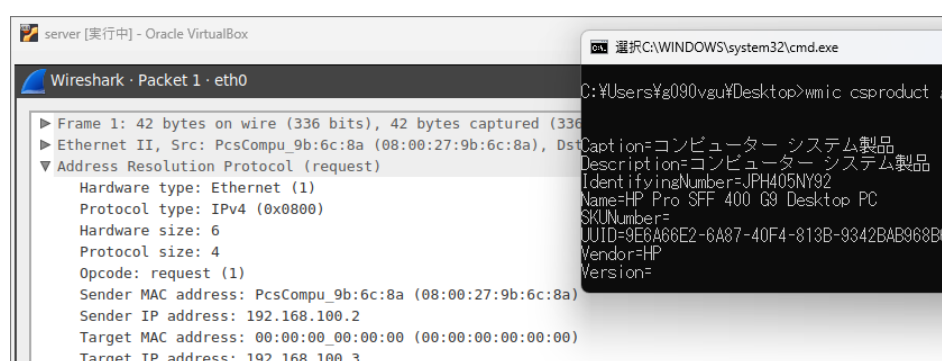


図 3 ARP リクエスト

図 3 では、server の IP アドレスである 192.168.100.2 から 192.168.100.1 の IP アドレスを解決するための ARP リクエストがブロードキャストされていることがわかる。

次に No.5 のパケットでユニキャストのパケットがキャプチャされていることが分かる。No.5 のパケットの詳細を図 4 に示す。

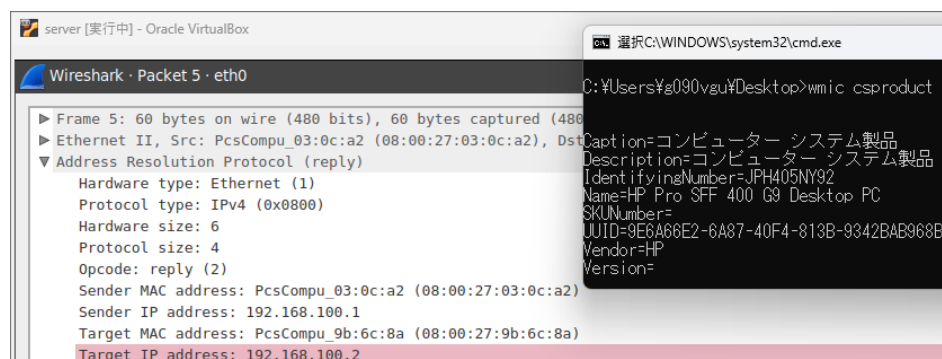


図 4 ARP 応答

図 4 から、このパケットは 192.168.100.1 から 192.168.100.2 への ARP 応答、すなわち、router から server へ返された ARP 応答である。

続いて No.68 にかけて再び ARP 要求パケットがブロードキャストされていることが分かる。これは 1 回目の ARP 要求に対する応答が得られなかった IP アドレスに対して、再度 ARP 要求がブロードキャストされたものであると考えられる。実際にキャプチャされたパケットにおいても ARP 要求の再送が行われているのは 192.168.100.[3,4,5] の IP アドレスに対してである。

次に、No.9 で DNS のパケットがキャプチャされている。このパケットの詳細について図 5 に示す。

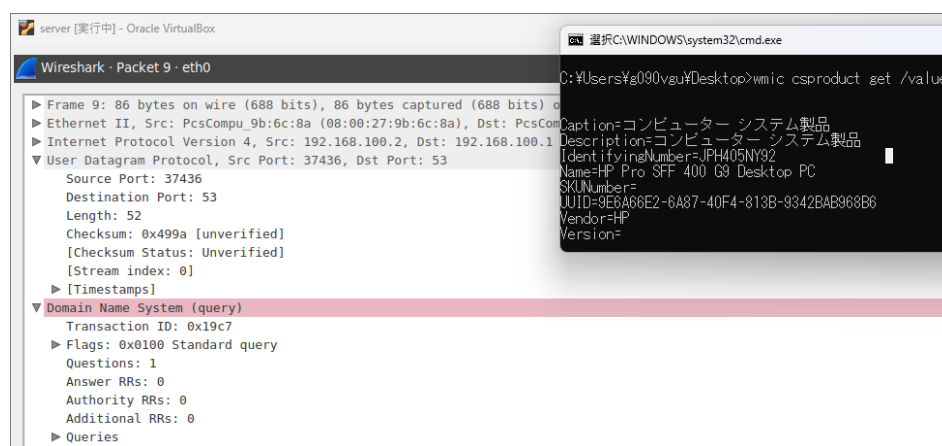


図 5 DNS 問い合わせ

図 5 から、jtodoj

次に No.10 で ICMP のパケットがキャプチャされている。このパケットの詳細について図 6 に示す。

図 6 から、ICMP → DNS → Transaction ID の値が図 5 の DNS 問い合わせの DNS → Transaction ID と同じであることから、このパケットは図 5 の DNS 問い合わせに対する応答であることがわかる。さらに、ICMP の Type が 3 で Code が 3 であることから、ポート到達不能による ICMP 到達不能メッセージであることがわかる。

以上の解析から、ping スキャンの実行に伴い、まず ARP リクエストが探索範囲に対して送信され、ARP 応答が返された IP のみが利用可能なホストとして検出されることがわかった。

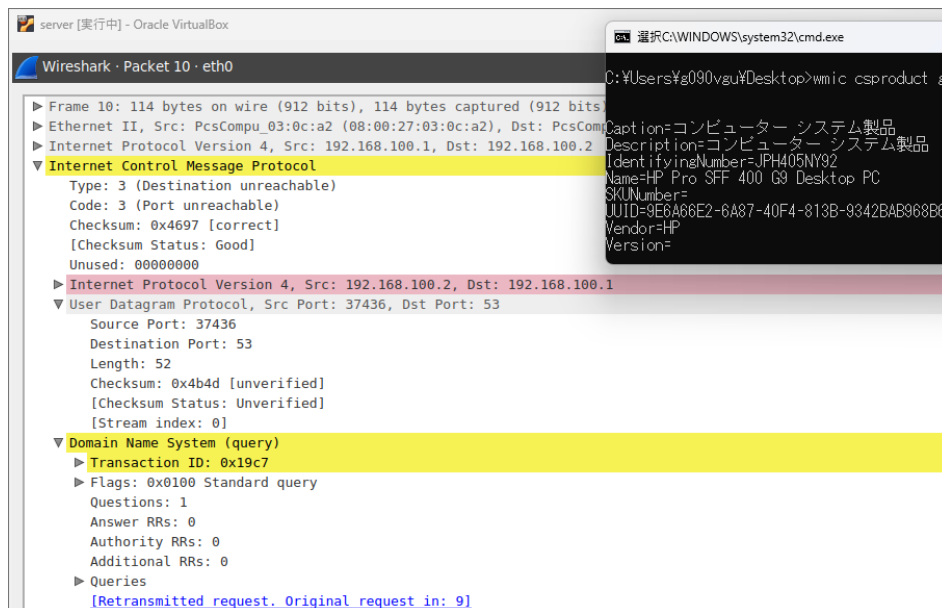


図 6 ICMP 到達不能メッセージ

(2) Nmap を使ったポートスキャン

サブゴール：探査用マシン (server) から、(1) ホスト検出で検出された各マシン（以下、被攻撃対象マシン）について順番に調査する

1 telnet と ssh のポート番号以外の違いで最も大きな違いは何か調査しなさい。

telnet と ssh はいずれもサーバ間のリモートアクセスに用いられるプロトコルであるが、ssh では通信内容が暗号化される一方で telnet においては暗号化する仕組みがない [5]。

2 3 種類のポートスキャンで、OSI 参照モデルのどの層で、どのような手順で、どのように、どのような情報が、やり取りされるか再確認し、整理しなさい。

3 種類のポートスキャンとは TCP connect スキャン, SYN ステルススキャン, UDP スキャンのことである。各ポートスキャンの詳細については以下の通りである。

i. TCP connect スキャン

この手法では他のほとんどのスキャンタイプと異なり、生パケットに書き込むのではなく、connect システムコールを発行して、ターゲットのマシンのポー

トとコネクションを確立するよう下位 OS に要求する。前述のとおり、高レベルのシステムコールを呼び出しており、制御の自由度や処理効率が低く、TCP コネクションを確立することからターゲットマシンのログにも残りやすい [3]。

TCP connect スキャンの手順は以下のとおりである。

ターゲットのポートが開放 (open) されている場合

- ① スキャン側から、ターゲットの対象ポートへ「接続したい」という要求 (SYN パケット) を送信する。
- ② ポートが開いているため、ターゲットから「接続を許可する」という応答 (SYN/ACK パケット) が返ってくる。
- ③ スキャン側から、さらに「確認した」という応答 (ACK パケット) を返す。

ターゲットのポートがポートが閉塞 (closed) している場合

- ① スキャン側から、ターゲットの対象ポートへ「接続したい」という要求 (SYN パケット) を送信する。
- ② ポートが閉じているため、ターゲットから「接続を拒否する」という応答 (RST/ACK パケット) が返ってくる。

図 7 は上述した TCP connect スキャンの手順を OSI 参照モデルに基づいて図解したものである。

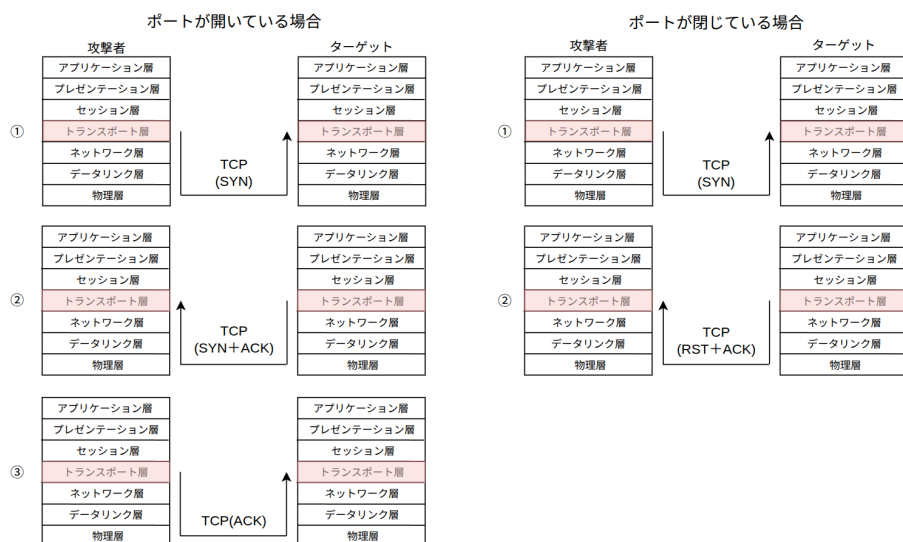


図 7 OSI モデルに基づいた TCP Connect スキャンによるデータの流れ ([6] より引用・改変)

このスキャン手法は TCP コネクション確立の手続きを利用してポートのスキャンを行うため、基本的には、それぞれのやり取りにおいてトランスポート層が起点・終点となってポートスキャンが行われる。一方で、フィルタリングやファイアウォールの存在によって、送信されたパケットがターゲットマシンのポートに到達しない場合もある。タイプ 3, コード 13 (宛先到達不能; 通信が管理上の理由で禁止されている) などの ICMP エラーメッセージを返すこともあるが、応答しないで応答しないでパケットを破棄することが多い [2]。このような場合は ICMP ヘッダや、何も応答がないことを理由にフィルタされている (filtered) と判定される [3]。したがって基本的には、TCP connect スキャンは TCP ヘッダのフラグ情報をもとに、トランスポート層 (第 4 層) 以下で動作すると言える。

ii. SYN ステルススキャン

nmap コマンドにおけるデフォルトのスキャン手法である。ファイアウォールによる妨害がなく、TCP コネクションも確立しないため、比較的秘匿性が高い。この手法では TCP コネクションを確立するわけではないため、ハーフオープンスキャンと呼ばれることも多い [3]。

SYN ステルススキャンの手順は以下のとおりである。

ターゲットのポートが開放 (open) されている場合

- ① スキャン側から、ターゲットの対象ポートへ「接続したい」という要求 (SYN パケット) を送信する。
- ② ポートが開いているため、ターゲットから「接続を許可する」という応答 (SYN/ACK パケット) が返ってくる。
- ③ スキャン側から、さらに「確認した」という応答 (RST パケット) を返す。

ターゲットのポートがポートが閉塞 (closed) している場合

- ① スキャン側から、ターゲットの対象ポートへ「接続したい」という要求 (SYN パケット) を送信する。
- ② ポートが閉じているため、ターゲットから「接続を拒否する」という応答 (RST/ACK パケット) が返ってくる。

図 8 は上述した SYN ステルススキャンの手順を OSI 参照モデルに基づいて図解したものである。

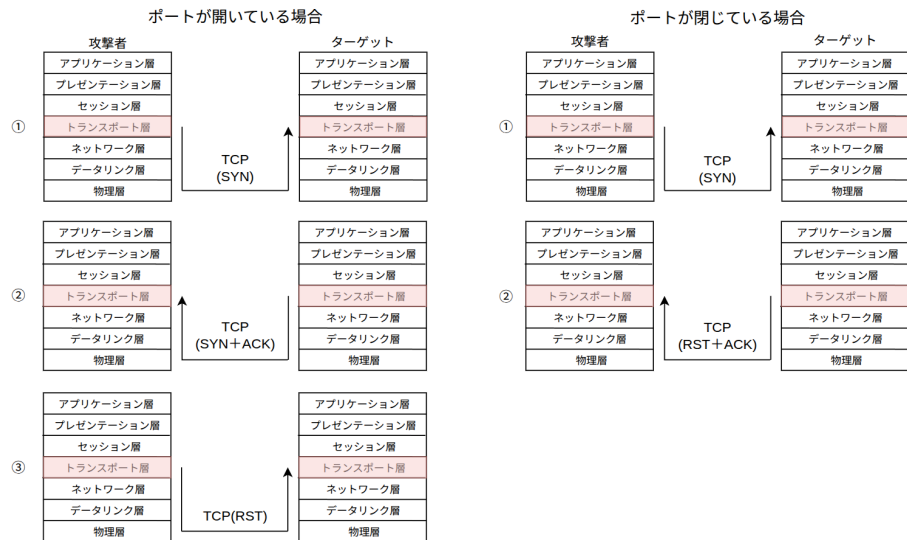


図 8 OSI モデルに基づいた SYN ステルススキャンによるデータの流れ ([6] より引用・改変)

このスキャン手法も TCP コネクション確立の手続きを利用してポートのスキャンを行うため、基本的には、それぞれのやり取りにおいてトランスポート層が起点・終点となってポートスキャンが行われる。TCP connect スキャンと異なるのは、TCP connect スキャンと同じく、一部例外を除けば基本的には図 8 の通りトランスポート層を起点・終点としてポートスキャンが実行されるため、SYN ステルススキャンは TCP ヘッダのフラグ情報をもとに、トランスポート層 (第 4 層) 以下で動作すると言える。

iii. UDP スキャン

空の (データなし)UDP ヘッダを各ターゲットポートに送ることで機能する。このスキャン手法の問題は、処理が低速な点である。ほか 2 つのスキャン手法と異なり、ポートが開いている場合にはターゲットからの応答がないため、パケットや応答が行方不明になった場合に備えて再試行を行うことになる。また、ポートが閉じている場合には ICMP ポート到達不能エラーが帰ってくるが、ICMP 到達不能メッセージはデフォルトでレート制限されているため、すべてのポートをスキャンするのに膨大な時間を要するという問題がある [3]。

UDP スキャンの手順は以下のとおりである。

ターゲットのポートが開放 (open) されている場合

- ① スキャン側から、ターゲットの対象ポートへ空の UDP ヘッダ（データなしパケット）を送信する。

ターゲットのポートが閉塞 (closed) している場合

- ① スキャン側から、ターゲットの対象ポートへ空の UDP ヘッダ（データなしパケット）を送信する。
- ② ポートが閉じているため、ターゲットの OS（ネットワーク層）から「ポートに到達できない」という応答（ICMP ポート到達不能エラー：Type 3, Code 3）が返ってくる。

図 8 は上述した UDP スキャンの手順を OSI 参照モデルに基づいて図解したものである。

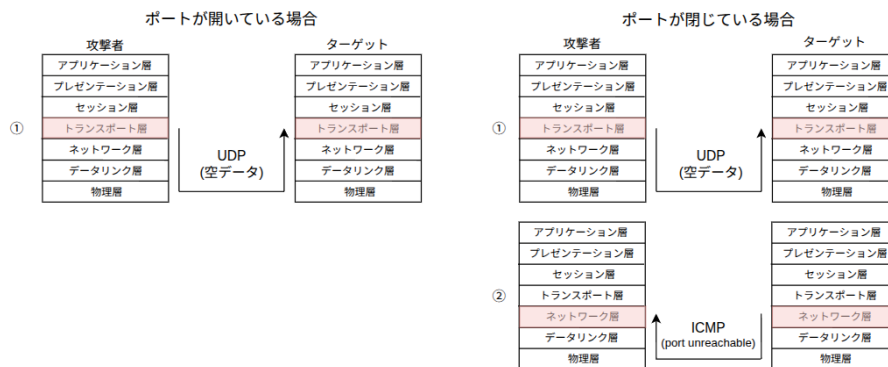


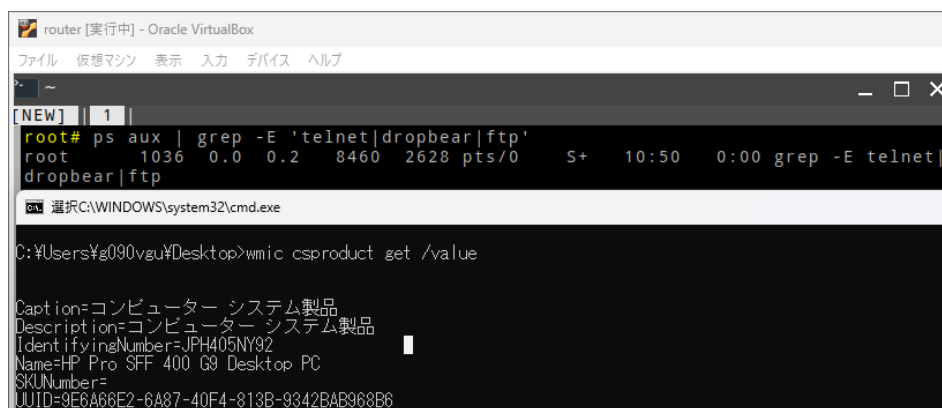
図 9 OSI モデルに基づいた UDP スキャンによるデータの流れ ([6] より引用・改変)

空の（データなし）UDP ヘッダを各ターゲットポートに送ることで機能する。基本的には、ICMP ポート到達不能エラー（タイプ 3, コード 1,2,9,10,13）が返された場合、ポートは閉じており (closed)、その他の ICMP ポート到達不能エラーが返された場合、ポートはフィルタされている (filtered)。まれにサービスが UDP パケットで応答する場合もあるが、その場合はポートは開いている (open) ことがわかる。数回の再試行の後にも応答がない場合にはポートは開いているあるいはフィルタされている (open—filtered) と判別することができる [3]。UDP スキャン手法もトランスポート層（第 4 層）以下で動くが、ほか 2 つの手法と異なり、この手法は基本的にポートの状態の判断は、ICMP エラーメッセージの有無（ネットワーク層）で行われる。

3 [被攻撃対象マシン] で telnetd と dropbear と ftp が起動していないことを確認する。起動している場合には停止させる。起動しているかどうかは ps コマンドなどで確認すること。

※ ftp は ftp という文字を含むプログラムが動いていないことを確認

図 10 は router において、ps コマンドと grep コマンドを組み合わせる telnetd と dropbear, ftp のプロセスが起動していないことを確認するコマンドを実行した結果である。



```
router [実行中] - Oracle VirtualBox
[NEW] 1
root# ps aux | grep -E 'telnet|dropbear|ftp'
root    1036  0.0  0.2  8460  2628 pts/0    S+   10:50   0:00 grep -E telnet|
dropbear|ftp

C:\Users\%g090v%u\Desktop>wmic csproduct get /value

Caption=コンピューター システム製品
Description=コンピューター システム製品
IdentifyingNumber=JPH405NY92
Name=HP Pro SFF 400 G9 Desktop PC
SKUNumber=
UUID=9E6A66E2-6A87-40F4-813B-9342BAB968B6
```

図 10 router における起動プロセスの確認

grep による条件を満たすプロセス (telnet または dropbear または ftp という文字列を含むプロセス) は、ここで実行した grep コマンドによるもののみであるため、telnet, dropbear, ftp いずれのプロセスも起動していないことが確認できる。

4 [探査用マシン] で Wireshark を起動し、以下の 4 つのポートスキャンによって生じた双方向の通信の内容を解析しなさい。

※ 先に以降の手順の意図を把握し、どのような結果を得るべきか考えて、解析をすることを奨める。また、適宜、解析を区切るなど、工夫して実施してもよい。

※ 結果の見通しをよくするためスキャン範囲を telnetd と dropbear が使用するポート番号の前後に絞ってもよいが、関係ないポートも一部含めること

telnet, dropbear が使用するポートはそれぞれ 23,22 である。ここでは、非攻撃対象マシンである router に対して telnet と dropbear のポートと ftp の利用するポートである 21 を含めた 21 から 23 の範囲にポートスキャンを行った。

・ TCP connect スキャンを行う。図??は TCP connect スキャンの実行結果で

ある。

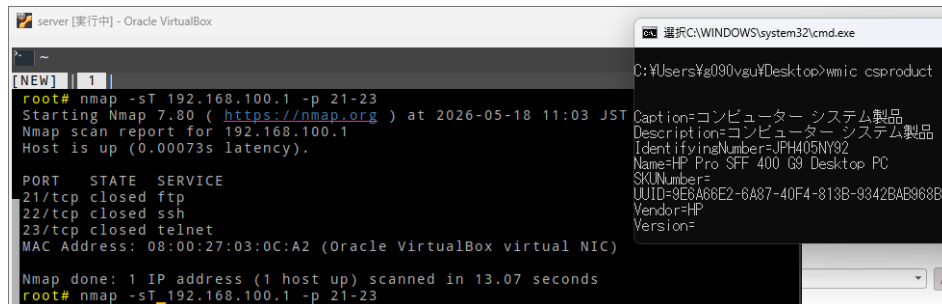


図 11 TCP connect スキャンの実行結果 1

telnet, dropbear が使用するポートはそれぞれ 23,22 である。ここでは、未関係のポート 21 を含めた 21 から 23 の範囲に対してスキャンを行っている。

- SYN ステルススキャンを行う。
- UDP スキャンを行う。
- TCP/IP fingerprinting を用いて OS を判別する。

5 [被攻撃対象マシン] で telnetd と dropbear と ftp を起動させる。dropbear を起動させる際には、オプションとして -R をつけること。FTP server は、既にインストールされているソフト (GUI) を起動させればよい。

6 telnetd と dropbear と ftp が起動していることを確認する。

7 [探査用マシン] から [被攻撃対象マシン] へ telnet および ssh で作成した一般権限ユーザ名でログインできることを確認する。

8 [探査用マシン] から [被攻撃対象マシン] へ telnet および ssh でログインする過程で生じた通信の内容を解析し、調査結果より想定される telnet と ssh の最も大きな違いが確認できることを、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。

ヒント：TCP stream でログイン時のパケット内の情報について確認する

9 再び、手順 4. を実行し、以前の手順 4. での結果 (出力とキャプチャパケットの面) と比較し、整理した各ポートスキャンの動作の仕組み (OSI 参照モデルのどの層で、どのような手順で、どのように、どのような情報が、やり取りされるか) を、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。

10 手順 8. の比較の内、TCP/IP fingerprinting を用いた OS 判別において、3 つのポートスキャン方法の内、どの方法が利用されているか、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。また、OS の検出結果について違いが起

きたか報告しなさい.

参考文献

- [1] Insecure.Org and Nmap Project. Nmap リファレンスガイド (Man Page). Nmap.org, <https://nmap.org/man/jp/index.html>. 閲覧日: 2026 年 6 月 2 日. 2026.
- [2] Insecure.Org and Nmap Project. Nmap リファレンスガイド (Man Page) — ポートスキャンの基本. Nmap.org, <https://nmap.org/man/ja/man-port-scanning-basics.html>. 閲覧日: 2026 年 6 月 2 日. 2026.
- [3] Insecure.Org and Nmap Project. Nmap リファレンスガイド (Man Page) — ポートスキャン手法. Nmap.org, <https://nmap.org/man/ja/man-port-scanning-techniques.html>. 閲覧日: 2026 年 6 月 2 日. 2026.
- [4] Insecure.Org and Nmap Project. Nmap リファレンスガイド (Man Page) — ホストの発見. Nmap.org, <https://nmap.org/man/ja/man-host-discovery.html>. 閲覧日: 2026 年 6 月 2 日. 2026.
- [5] Tomoya. Linux の基礎を知る (Telnet と SSH). July 31, 2023. URL: <https://www.miraclejob.com/recommend/detail?cd=4085> (visited on 06/01/2026).
- [6] 福士 将 et al. 情報ネットワーク特論・実験 第 5 週目 「不正アクセスにおける探査段階」. 閲覧日: 2026 年 6 月 2 日. 山口大学. 2026.